

CYPRUS REPUBLIC

COMMISSIONER

File No.: 11.17.001.011.059

OFFICE OF THE COMMISSIONER FOR PERSONAL DATA PROTECTION

Complaint regarding the disclosure of a medical certificate to a third party

DECISION

Case Incidents

Positions of the Complainant

In the complaint, and in letters from the complainant's lawyers, dated

Based on the duties and powers conferred upon me by Article 57(1)(f) of Regulation (EU) 2016/679 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (hereinafter referred to as the "Regulation"), I examined a complaint submitted to my Office on April 5, 2023, by Mr. XXX (hereinafter referred to as the "complainant"), regarding the disclosure of a medical certificate by Dr. XXX (hereinafter referred to as the "Respondent").

Based on the investigation, I found a violation of the Regulation by the Respondent and, therefore, I issue this Decision.

A.

2. On April 10 and 12, 2023, it was reported that:

2.1. between the complainant and his ex-wife, there was an ongoing judicial process before the Family Court of Nicosia and the Supreme Court at the time of the complaint submission,

2.2. the complainant's ex-wife used her position as a doctor to obtain from the Respondent a report concerning the complainant for her personal benefit,

2.3. the complainant's ex-wife presented to the Family Court of Nicosia a medical certificate dated November 11, 2022, signed by the Respondent, which concerns the complainant. This certificate was issued without the complainant's knowledge and consent, with the intention of being used by his ex-wife in their judicial proceedings,

2.4. the judicial process before the Family Court of Nicosia commenced in XXX 2022, that is, before the issuance of the medical certificate,

2.5. there are two violations concerning the complainant:

2.5.1. disclosure by the Respondent to the complainant's ex-wife,

2.5.2. from the complainant's ex-wife to the Court,

2.6. the complaint does not concern the above 2.5.2. violation, namely the disclosure from the complainant's ex-wife to the Court, in which the Court is involved,

2.7. there is no ongoing judicial process against the Respondent. The judicial process does not concern the Respondent at all, nor does it affect or is it affected by the complaint,

2.8. the Respondent acted in violation of Law 125(I)/2018, and the action of the Respondent is particularly serious as it concerns personal medical data, which must be afforded enhanced protection due to the provisions of the Law on the Safeguarding and Protection of Patients' Rights of 2004, Law 1(I)/2005,

2.9. on December 20, 2022, a letter dated December 14, 2022, was served on behalf of the complainant to the Respondent, with inquiries regarding his actions. However, the Respondent did not respond to this letter. The letter states that the actions of the Respondent were in violation of:

2.9.1. the European Convention on Human Rights (Article 8),

2.9.2. the constitutional right to privacy (Article 15),

2.9.3. the Law on the Protection of Natural Persons Against the Processing of Personal Data and the

Free Movement of Such Data of 2018, Law 125(I)/2018 - (GDPR),

2.9.4. the Law on the Safeguarding and Protection of Patients' Rights of 2004, Law 1(I)/2005 (Article 15),

2.10. the Family Court of Nicosia has reached and issued an interim Decision dated XXX 2023, and within the framework of the interim judicial process, the admissibility of the testimony of the medical documents was not an issue, and there is no pending matter concerning the said documents.

In the above correspondence, on behalf of the complainant, the following were attached:

- (a) a medical certificate signed by the Respondent, dated November 11, 2022, which bears a stamp and the seal of the Family Court of Nicosia. In this certificate, in the field "Name," the name of the complainant's ex-wife "XXX" is written. It also states that: "I certify that XXX underwent surgery in March 2014 for the removal of a cataract from the left eye and in September 2014 for the removal of a cataract from the right eye. He was accompanied by his wife XXX during both surgeries.",
- (b) a letter from the complainant's lawyer to the Respondent, dated December 14, 2022, as referenced in paragraph 2.9 of this document, which is accompanied by the medical certificate mentioned in paragraph 2(a) of this document. An affidavit of service of the letter to the Respondent, dated December 22, 2022, is also attached,
- (c) a document of appointment,

2

****Positions of the Respondent****

On April 12, 2023, my office sent a letter to the Respondent, with

In a letter from the Respondent's lawyers, dated May 15, 2023, in response
Decision of the Family Court of Nicosia, dated XXX 2023, as

(d)

it is referenced in paragraph 2.10 of this document.

3.

questions regarding the incident and the claims of the complainant.

4.

In the aforementioned letter from my office, among other things, the following was mentioned:

4.1. The complainant was operated on by the Respondent in March and September of 2014. During these surgeries, he was accompanied by his wife, XXX.

4.2. According to the medical diary maintained by the Respondent, the complainant visited him on March 19, 2018, January 21, 2020, February 9, and July 21, 2022, at his private practice in Nicosia. During these visits, the complainant always spoke highly of his wife, even providing details regarding her work and expressing, in every case, his admiration and appreciation for her.

4.3. Around November 11, 2022, the complainant's wife visited the Respondent's office and requested a certificate for the days she accompanied her husband to Hospital XXX for cataract removal. When the Respondent asked the complainant's wife to specify the reason for requesting this certificate, she mentioned that there were disputes with the complainant's children. The complainant's wife did not mention to the Respondent anything regarding divorce proceedings between herself and the complainant. The Respondent, convinced that the document in question pertained to a "dispute between the husband and his children," proceeded to issue the said certificate.

4.4. Neither the complainant nor his wife had ever mentioned to the Respondent that they were in the process of obtaining a divorce.

4.5. The Respondent proceeded to issue the said certificate convinced that the exception of Article 9, paragraph 2, subparagraph (f) of the Regulation applied, namely the establishment, exercise, or support of legal claims, which constitutes an exception to the prohibition of processing personal data set forth in Article 9, paragraph 1 of the Regulation.

4.6. The Respondent's lawyers believe that the processing of the complainant's data was lawful and, in

any case, the justification for issuing the certificate was at least the result of deception of the Respondent by the complainant's estranged wife. They also hold the view that the use made by the complainant's estranged wife falls under the exception of Article 9, paragraph 2, subparagraph (f) of the Regulation, as the document in question was used in judicial proceedings and was never published to the general public in a manner that would violate the complainant's personal data.

****Legal Aspect****

****Positions of the Complainant****

On August 8, 2023, the complainant's lawyers stated to the

Based on the evidence submitted by the Respondent, my office sent a letter dated July 27, 2023, with

5.

to the complainant's lawyers, clarifying questions,

6.

My office stated, among other things, the following:

6.1. All claims and/or positions of the Respondent are rejected, except for his claim regarding the deception by the complainant's ex-wife.

6.2. The only claim that can be accepted and/or is valid is the Respondent's claim that the justification for issuing the medical certificate was the result of deception of the Respondent by the complainant's ex-wife, and only this is satisfied and/or accepted by the complainant.

B.

7. According to Article 4 of the Regulation, personal data is interpreted as "any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person."

8. As health data, as provided by the same article of the Regulation, are described as "personal data which relate to the physical or mental health of a natural person, including the provision of health care services, and which reveal information about the health status of that person."

9. As the data controller, Article 4 of the Regulation defines "the natural or legal person, public authority, agency, or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union law or the law of a Member State, the controller or the specific criteria for its designation may be provided for by Union law or the law of a Member State."

10. Regarding the principles that should govern the processing of personal data, Article 5 of the Regulation provides that:

Personal data:

"1. shall be processed lawfully and fairly in a transparent manner in

a) relation to the data subject ('lawfulness, fairness, and transparency'),

****11.**** Regarding the processing of special categories of personal data, Article 9 of the Regulation provides the following:

Paragraph 1 does not apply in the following cases:

"1. The processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, as well as the processing of genetic data, biometric data for the purpose of unequivocal identification of a person, data concerning health, or data concerning the sexual life of a natural person or sexual orientation is prohibited.

2.

a) The data subject has given explicit consent to the processing of these personal data for one or more specific purposes, unless Union or Member State law provides that the prohibition referred to in

paragraph 1 may not be lifted by the data subject,

b) The processing is necessary for the performance of obligations and the exercise of specific rights of the data controller or the data subject in the field of employment law and social security and social protection law, provided that it is permitted by Union or Member State law or by a collective agreement in accordance with national law,

c) The processing concerns personal data which have been provided, offering appropriate safeguards for the fundamental rights and interests of the data subject,

d) The processing is necessary for the protection of the vital interests of the data subject or another natural person, if the data subject is physically or legally incapable of giving consent,

e) The processing is carried out, with appropriate safeguards, in the course of the legitimate activities of a foundation, association, or other not-for-profit body with a political, philosophical, religious, or trade union aim and on the condition that the processing relates solely to the members or former members of the body or to persons who have regular contact with it in connection with its purposes and that the personal data are not disclosed outside that body without the consent of the data subjects,

f) The data has been made public by the data subject,

g) The processing is necessary for the establishment, exercise, or defense of legal claims or when courts are acting in their judicial capacity,

h) The processing is necessary for reasons of substantial public interest, based on Union law or...

****Member State****, which is proportional to the intended objective, respects the essence of the right to data protection and provides appropriate and specific measures to ensure the fundamental rights and interests of the data subject,

****h)****

the processing is necessary for the purposes of preventive or occupational medicine, assessment of the employee's working capacity, medical diagnosis, provision of health or social care or treatment, or management of health and social systems and services based on Union law or the law of the Member State or pursuant to a contract with a health professional and subject to the conditions and guarantees referred to in paragraph 3, the processing is necessary for reasons of public interest in

****i)****

the field of public health, such as the protection against serious cross-border threats to health or the ensuring of high standards of quality and safety of health care and medicinal products or medical devices, based on Union law or the law of the Member State, which provides appropriate and specific measures for the protection of the rights and freedoms of the data subject, in particular the professional secrecy, or

****j)****

the processing is necessary for archiving purposes in the public interest, for scientific or historical research purposes, or for statistical purposes in accordance with Article 89 paragraph 1 based on Union law or the law of the Member State, which are proportional to the intended objective, respect the essence of the right to data protection and provide appropriate and specific measures to ensure the fundamental rights and interests of the data subject.

3. Personal data referred to in paragraph 1 may be processed for the purposes provided for in paragraph 2 point ****h)**** when such data are processed by or under the responsibility of a professional who is subject to the obligation of professional secrecy under Union law or the law of the Member State or under rules established by competent national authorities or by another person who is also subject to the obligation of confidentiality under Union law or the law of the Member State or under rules established by competent national authorities.

4. Member States may maintain or establish further conditions, including restrictions, regarding the processing of genetic data, biometric data, or data concerning health.

12. Under Article 57, paragraph 1, point ****f)**** of the Regulation, the Commissioner for Personal Data Protection has the duty to:

“handle complaints lodged by the data subject or by a body or organization or association in accordance with Article 80 and investigate, to the extent appropriate, the subject matter of the

complaint and inform the complainant of the progress and outcome of the investigation within a reasonable time, particularly if further investigation or coordination with another supervisory authority is required.”

13. Regarding the submission of a complaint to the Supervisory Authority, Article 77 of the Regulation provides that:

“Subject to any other administrative or judicial remedies, every data subject has the right to lodge a complaint with a supervisory authority, in particular in the Member State of their habitual residence or place of work or the place of the alleged infringement, if the data subject considers that the processing of personal data concerning them infringes this Regulation.”

14. Under Article 58, paragraph 2, of the Regulation, the Commissioner for Personal Data Protection has the following corrective powers:

- **a)** to issue warnings to the controller or the processor that intended processing operations are likely to infringe provisions of this Regulation,
- **b)** to issue reprimands to the controller or the processor when processing operations have infringed provisions of this Regulation,
- **c)** to order the controller or the processor to comply with the requests of the data subject to exercise their rights under this Regulation,
- **d)** to order the controller or the processor to bring processing operations into compliance with the provisions of this Regulation, if necessary, in a specific manner and within a specified time limit,
- **e)** to provide the data subject with personal data,
- **f)** to prohibit processing,
- **g)** to order rectification or erasure of personal data or restriction of processing under Articles 16, 17, and 18 and to order notification of such actions to recipients to whom the data have been disclosed,
- **h)** to impose a temporary or definitive limitation, including the obligation for the controller to notify the breach.

****Personal Data Notification Under Article 17 Paragraph 2 and Article 19****

- h) To withdraw the certification or to order the certification body to withdraw a certificate issued in accordance with Articles 42 and 43 or to order the certification body not to issue certification, provided that the certification requirements are not met or are no longer met,
- i) To impose an administrative fine under Article 83, in addition to or instead of the measures referred to in this paragraph, depending on the circumstances of each individual case,
- j) Third country or international organization. To order the suspension of data flow to a recipient.

****Regarding the General Terms of Imposing Administrative Fines, Article 83,****

15. Paragraph 2 of the Regulation provides the following:

“2. Administrative fines, depending on the circumstances of each individual case, are imposed in addition to or instead of the measures referred to in Article 58 paragraph 2 points a) to h) and in Article 58 paragraph 2 point i). In deciding on the imposition of an administrative fine, as well as on the amount of the administrative fine for each individual case, the following are duly taken into account:

- a) The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the relevant processing, as well as the number of data subjects affected by the infringement and the degree of damage suffered, the intent or negligence that caused the infringement,
- b) Any actions taken by the data controller or the processor to mitigate the damage suffered by the data subjects,
- c) The degree of responsibility of the data controller or the processor, taking into account the technical and organizational measures they have implemented under Articles 25 and 32,
- d) The processor,
- e) The infringement and the limitation of its potential adverse effects,

- f) The manner in which the supervisory authority became aware of the infringement, in particular whether and to what extent the data controller or the processor notified the infringement,
- g) In cases where measures referred to in Article 58 paragraph 2 were previously ordered against the involved data controller or processor regarding the same subject matter, compliance with those measures,
- h) Approved certification mechanisms in accordance with Article 42 and
- i) Any other aggravating or mitigating factor arising from the circumstances of the specific case, such as the financial benefits gained or damages avoided, directly or indirectly, from the infringement. The categories of personal data affected by any relevant previous infringements of the data controller or the degree of cooperation with the supervisory authority for the remedy of the infringement, compliance with approved codes of conduct in accordance with Article 40 or

****3.**** In cases where the data controller or the processor, for the same or related processing operations, infringes several provisions of this regulation, the total amount of the administrative fine does not exceed the amount set for the most serious infringement.

****4.**** Infringements of the following provisions incur, according to paragraph 2, administrative fines of up to 10,000,000 EUR or, in the case of enterprises, up to 2% of the total worldwide annual turnover of the preceding financial year, whichever is higher:

- a) The obligations of the data controller and the processor under Articles 8, 11, 25 to 39 and 42 and 43, the obligations of the certification body under Articles 42 and 43,
- b)
- c) The obligations of the monitoring body under Article 41 paragraph 4.

****5.**** Infringements of the following provisions incur, according to paragraph 2, administrative fines of up to 20,000,000 EUR or, in the case of enterprises, up to 4% of the total worldwide annual turnover of the preceding financial year, whichever is higher:

- a) Applicable for approval, according to Articles 5, 6, 7 and 9,
- b) Up to 22,
- c) Or to an international organization according to Articles 44 to 49,
- d) Established under Chapter IX,
- e) Non-compliance with an order or with a temporary or definitive restriction of processing or with the suspension of data flow imposed by the supervisory authority under Article 58 paragraph 2 or failure to provide access in violation of Article 58 paragraph 1.

****The transfer of personal data to a recipient in a third country****

The basic principles for processing, including the terms that the rights of data subjects according to Articles 12

Any obligations under the law of the member state

****Recital****

****G.****

16. The investigation I have conducted concerns only the issuance and notification of the medical certificate by the subject to the complainant's ex-wife. The use of the certificate by the complainant's ex-wife is not the subject of the investigation. I remind that the complainant's lawyers stated in the complaint that the complaint does not concern the "leak" from the complainant's ex-wife to the Court.

17. Any use and/or processing carried out by the complainant's ex-wife, based on the purposes she has defined, makes her the data controller, with all the obligations arising from the Regulation.

18. The subject held the data of the complainant and issued the certificate. Therefore, for the act of processing under investigation, he is considered the data controller.

19. In the certificate, in addition to the date of issuance, the details of the subject, and the details of the complainant (full name), it is stated that "I certify that XXX underwent surgery in March 2014 for the removal of a cataract in the left eye and in September 2014 for the removal of a cataract in the right

eye. He was accompanied by his wife XXX during both surgeries."

20. The certificate included information concerning both the complainant and his former wife, as it refers to her and her actions (i.e., that she accompanied the complainant during the surgeries performed by the subject in 2014). The fact that his former wife requested to receive a certificate for her actions, thus for her data, does not automatically mean that she is entitled to receive, without conditions, personal data of other individuals, specifically that of the complainant, even if that data was known to her.

The data included in the certificate (reference to "surgeries," specification of the surgeries and the time they took place) constitutes health data, that is, special categories of personal data. For the processing of such data, the provisions of Article 9 of the Regulation must be adhered to. Specifically, as mentioned in paragraph 1 of this article, the processing of such data is prohibited unless one of the cases in paragraph 2 applies.

22. Since the former wife of the complainant informed the subject that there were disputes with her husband's children, the subject was convinced that the document in question concerned a "dispute between her husband and his children," and for this reason proceeded with the issuance of the said certificate. Furthermore, as he stated, the subject proceeded with the issuance of the said certificate convinced that the exception of Article 9 paragraph 2 subparagraph (f) of the Regulation applies, namely the establishment, exercise, or defense of legal claims, which constitutes an exception to the prohibition on processing personal data set forth in Article 9, paragraph 1 of the Regulation.

23. The subject was obliged to assess and/or verify whether the granting of such a certificate would not conflict with his obligations as a data controller, since the certificate records personal data of the complainant. Even in the case that there was a dispute between the complainant and his children, and the certificate would be used for the establishment, exercise, or support of legal claims, the subject should have confirmed this with the complainant, especially since the certificate was issued eight years after the surgeries performed by the subject. Therefore, Article 9(2)(f) of the Regulation cannot be considered as a legal basis.

24. The fact that the subject stated that the rationale for issuance was "at least the result of deception" by the former wife of the complainant indicates that there were actions that the subject could have taken to avoid being deceived, specifically to confirm the former wife's statements with the complainant.

25. The processing of the complainant's data cannot be based on Article 9(2)(a) of the Regulation, as the complainant did not provide explicit consent.

26. The processing of special categories of personal data may be carried out if it concerns data that has been manifestly made public by the data subject, in accordance with Article 9(2)(e) of the Regulation. The complainant allowed his former wife to accompany him during his surgeries. However, this does not mean that the subject is entitled to prepare a written certificate regarding the complainant's surgeries and to disclose it to his former wife, especially when eight years have passed since the surgeries. It is possible that the complainant allowed his former wife to know other data concerning the surgeries or his health. However, even if this possibility holds, it does not mean that the disclosure of such data is legitimized.

27. Beyond the above, it appears that the processing cannot be based on any other case of Article 9(2) of the Regulation. Specifically and briefly, the processing of the complainant's data cannot be based on:

27.1. Article 9(2)(b) of the Regulation, as the processing was not necessary for the performance of the obligations and the exercise of specific rights of the subject or the complainant, or his former wife in the field of labor law and social security and social protection law.

27.2. Article 9(2)(c) of the Regulation, since the complainant was not physically or legally incapable of consenting, and the processing of his data was not necessary for the protection of his vital interests,

27.3. Article 9(2)(d) of the Regulation, since the processing was not carried out within the framework of

the legitimate activities of a foundation, organization, or other non-profit entity with a political, philosophical, religious, or trade union aim,

27.4. Article 9(2)(g) of the Regulation, since the processing was not necessary for reasons of substantial public interest,

27.5. Article 9(2)(h) of the Regulation, since the processing was not necessary for purposes of preventive or occupational medicine, assessment of the employee's working capacity, medical diagnosis, provision of health or social care, or treatment or management of health and social systems and services,

27.6. Article 9(2)(i) of the Regulation, since the processing was not necessary for reasons of public interest in the area of public health,

27.7. Article 9(2)(j) of the Regulation, since the processing was not necessary for archiving purposes in the public interest, for scientific or historical research purposes, or for statistical purposes.

28. Based on the above, it appears that the Controller processed health-related data without a legal basis, in violation of Article 9(2) of the Regulation. Furthermore, considering that the complainant was not informed about this, it follows that the Controller did not adhere to the Principle of legality, objectivity, and transparency, namely Article 5(1)(a) of the Regulation, since his data was not subjected to lawful and fair processing in a transparent manner.

Conclusion

29. Regardless of the above, even if the Controller determined that there was a legal basis for the said processing, the question arises as to why the Controller specifically mentioned the interventions to which the complainant underwent (removal of cataract from the right eye and removal of cataract from the left eye), and did not suffice with a simple reference that the complainant underwent two interventions in March and September 2014.

30. I recognize, however, as a mitigating factor the fact that the said data, namely the performance of the specific interventions, was known to the former spouse of the complainant, because the complainant himself allowed this. It was already known to the former spouse of the complainant what is recorded in the certificate, as it was also known to the complainant that his former spouse was aware of this information.

D.

31. Taking into account all the above elements, as they have been presented, and based on the powers conferred upon me by Article 57(1)(f) of the Regulation, I find that there is a violation by Dr. XXX of:

31.1. Article 5(1)(a) of the Regulation (EU) 2016/679, because the complainant's data was not subjected to lawful and fair processing in a transparent manner,

31.2. Article 9(2) of the Regulation (EU) 2016/679, because the issuance and communication of the certificate, which included health-related data, lacked legality.

32. Based on the provisions of Article 83 of the Regulation, regarding the conditions for imposing administrative fines, insofar as they apply to the specific case, in determining the administrative fine, I took into account the following mitigating (a) - (c) and aggravating (d) - (f) factors:

(a) the fact that the personal data of the complainant that was communicated was already known, because the complainant himself allowed his former spouse to accompany him to the interventions,
(b) it was communicated,

(c)

(d) categories of data,

(e) and the interventions to which the complainant underwent were specified,

(f) the fact that the certificate was issued eight years after the interventions.

33. After considering and weighing:

(a) the provisions of Article 58(2) and Article 83 of the Regulation,
(b) before me based on all existing correspondence, the cooperation of the Controller with my Office, the categories of data that were violated, which concern special circumstances and all factors that the complainant and the Controller presented, the fact that the certificate was not limited to absolutely necessary data, the applicable legislative basis regarding the prescribed administrative sanctions, the fact that the certificate also included data of the person to whom

the above mitigating and aggravating factors,

(c)

I find that, under the circumstances, the imposition of an administrative fine is not justified.

34. Nevertheless, taking into account the aforementioned facts, the legal aspect on which this Decision is based, and the analysis as explained above, and exercising the powers conferred upon me by Article 58(2)(d) of the Regulation,

I have decided

in my judgment and in accordance with the above provisions, to issue a reprimand to Dr. XXX

for the violation of Articles 5(1)(a) and 9(2) of the Regulation (EU) 2016/679 and to call upon him not to repeat such processing without the appropriate legal basis.

Irini Loizidou Nikolaidou

Commissioner for the Protection of Personal Data

February 28, 2024